

Block 13: session/workflow progress and signer/storage policy, final audit

Date: 2026-09-29. Auditor: Claude (Sonnet 5.5). Isolated checkout: /private/tmp/kk715-b13, branch audit/715-block13-20260929, fork draft PR #890. Base: 41c7cd7f0, the Block 12 head (PR #889), which already contains the completed Block 11. Historical PR #843 (head 8bf9047461a2a87646510f2083c9ead0e4fe701c) is unchanged. The exact final head and its hosted run are recorded in PR #890, because a report committed at a head cannot name that head.

1. Scope and provenance

The agent-2 isolated clone no longer existed. Its work survived as a verified Git bundle in the agent-2 vault (docs/security/715-block13/715-block13.bundle, integrated head f44f2537b). Block 13's own three commits were cherry-picked onto the Block 12 head instead of merging the old provisional chain: 123bb0335 (empty recovery input, intake), 9871ccf23 (workflow, entropy and recovery findings) and 7e7e0edea (recovery fixture isolation). The bundle's other commits are Block 11 and Block 12 history already present in the base. Block 13's own commits change 40 paths over Block 12; with this report, its PDF and its evidence archive the final adjacent inventory in section 6 lists 43. The historical 34-path reconciliation and the intake are carried unchanged (715-13-path-reconciliation-20260927.json, 715-13-intake-20260927.md).

Conflict resolutions, following the 2026-09-28 readiness handoff:

File	Resolution
lib/firmware/fsm.c	Block 11's shared CHECK_STORAGE_WRITABLE inside CHECK_NOT_INITIALIZED is kept. Block 13's duplicate guard is dropped. Its real-handler tests are kept
.github/workflows/ci.yml	Waivers are storage-v19-kdf, solana-lut-attestation: Block 13 removes entropy-audit-budget and osmosis-wire-guards, Block 12 already removed hive-release-review
scripts/generate-test-report.py	All six contract suites kept, including junit-stack13.xml in both variants, plus Block 12's exactly-once Hive rule
scripts/emulator/python-keepkey-tests.sh	Stack 12 and Stack 13 steps both kept

2. Findings from the historical audit

Finding	Disposition here
S13-001 empty recovery character	Repaired. Empty input gives a syntax failure, disarms setup and keeps the original idle deadline
S13-002 malformed tiny packets during a pending signing approval	Historical gap refuted; existing rejection latch and confirmation unwind retained
S13-003 recovery redraw	Repaired. The same cipher mapping is restored without another CharacterRequest

Finding	Disposition here
S13-004 entropy request budget	Repaired. Requests clamp at 1,024 bytes, press-free returns are charged against 65,536 bytes while uninitialized, zero size is free, armed setup is refused, and initialized or retained storage requires consent
S13-005 Osmosis send amounts	Repaired, then narrowed by this audit. Canonical decimal strings are accepted; padded, signed, fractional, exponent, spaced, empty or omitted amounts are refused as syntax errors before review. The uint64 bound applies to the native uosmo denomination only, as the pinned Python test requires. Other denominations keep the wire limit of 32 digits and the exact integer is displayed and signed. Swap and pool amounts keep their wider domain
S13-006 workflow idle lease	Repaired. Only an accepted initialization or a validated, reviewed non-final update renews the lease; invalid, empty or declined inputs and GetFeatures/Ping cannot
S13-007 Ripple memo serialization	Historical change technically declined; the existing encoding and length-prefix fix are preserved
S13-008 newer retained storage	Repaired historically, now protected by Block 11's shared guard. Block 13 keeps independent real-handler regression coverage, so attribution moves to Block 11 while the security contract is unchanged

3. Audit round

Two independent read-only source audits covered the merged diff. The product audit found no serious defect and no merge-interaction defect: wallet creation refuses before any confirmation or arming under the merged guards, the entropy budget cannot underflow and a refused request spends nothing, empty recovery input is rejected, and the layout signature change has a single caller. The tests-and-gates audit found no test that expects a message or count the merged code does not produce, and no gate inconsistency. It named the one place CI could go red: removing two waivers makes previously skipped Python tests mandatory.

Decisions on the audit's three observations:

- **Osmosis send cap: fixed** (a1941dfa8, test corrected in 77e2d752f). The uint64 bound was applied to every denomination, so an 18-decimal IBC or factory asset could not be sent above about 18.4 tokens. It now applies to uosmo only. The wire already limits the amount to 32 digits and the denomination to 68 characters, so the worst-case screen string is 101 bytes in a 128-byte buffer, and the signer hashes the amount in segments with no fixed buffer. The first hosted run of the new test failed with `ActionCancelled` because a wide amount beside a long denomination paginates over several confirmation screens and only one approval was preloaded; the amount had passed validation and reached review, so the test was corrected, not the product change.
- **Auto-lock renewal by valid starts: tracked, not changed** (issue #891). Accepted workflow starts renew the deadline, so a connected host can keep an already-unlocked device from auto-locking by sending valid starts. This is Block 13's tested design (invalid starts, declined confirmations and idle polling cannot renew), it is needed so a workflow begun just before the

deadline can finish, and Ethereum ClearSign and Bitcoin already behave this way in the base. Fixing it means splitting start and progress renewals across about 15 call sites and re-testing, so it needs the owner's decision.

- **Recovery cipher re-roll on an empty delete: not a defect, unchanged.** Every CharacterAck gets a freshly scrambled cipher and a CharacterRequest reply; that is how the scheme works, and the mapping is never sent to the host. The audit's suggested redraw would send no CharacterRequest and hang the host.

4. Verification

Check	Result
Hosted run 36616834395 at 77e2d752f	Passed every required job, publishing skipped. This is the last product-code head. The earlier run 36608080733 at 922922bb7 also passed, before the Osmosis narrowing. The one failed run, 36614284576 at a1941dfa8, failed only on the new test's approval count, described above
Native firmware	773 full and 197 Bitcoin-only (Block 12's 718 and 179 plus the Block 13 identities and the two new Osmosis tests); board 28 and crypto 18 in each variant, in both harnesses
Block 13 native identities	54 named cases pass in the full build and 17 in Bitcoin-only, plus the Osmosis identity the gate also requires; the gate now requires 55 full and 18 Bitcoin-only, including the two new tests; zero skips or failures
Dedicated entropy wire	5 of 5 pass in both variants
Newly mandatory Python tests	test_entropy, test_present_but_empty_amount_is_rejected_as_invalid and test_osmosis_send_rejects_noncanonical_wire_amounts pass; skips fell from 76 to 73 accordingly
ARM	Both variants build and pass the SRAM gate; 23 files each, hashes match the manifests
Aggregate	1,645 pass, 73 skip, 0 fail; Python pin 05c77c948d61c2a6a23aaf961ad7c45037ac739b
Control: storage guard	Hosted run 36610417163 on a throwaway branch that removes only CHECK_STORAGE_WRITABLE from CHECK_NOT_INITIALIZED: Block13Entropy.NewerNormalBandRefusesAllWalletCreationUntilWipe and NewerBitcoinBandRefusesAllWalletCreationUntilWipe fail in both variants, alongside Block 11d's IncompatibleStorage creation cases (7 failures full, 6 Bitcoin-only, everything else passes). Block 13's tests therefore still protect S13-008 under the merged guard
Control: Osmosis cap	Hosted run 36616837620 on a throwaway branch that restores the uint64 bound for every denomination: only Block13osmosisWire.NonNativeDenominationsAreNotCappedAtUInt64 fails, in the full build (773 tests, 1 failure); Bitcoin-only is unaffected because Osmosis is full-only (197 tests, 0 failures)
Local	Preflight passes except cppcheck (local Docker is unresponsive; hosted static analysis passed), including clang-format 20, CMake membership of the three new native suites, report tests (25) and workflow lint. Local no-git secret scan: no findings in tracked paths

Artifacts were downloaded and verified against the exact head. The historical negative controls in 715-13-evidence/ were run on the pre-merge source and are inherited evidence, not re-executed on the merged tree. Evidence archive 715-13-final-controls-20260929.tgz binds the local logs, the hosted verification output and the control result.

5. Not claimed

Physical-device behaviour, OLED readability and actual power cycles remain release gates; debuglink text is not a substitute. Merge and release acceptance are not claimed, and this document does not claim a Copilot review. The historical eight-finding attribution is preserved rather than rewritten.

6. Adjacent inventory

Inventory base: 41c7cd7f0. Reproduce with `git diff --numstat BASE..FINAL_PR_HEAD` after the report, PDF and archive are committed.

Added	Deleted	Path
9	3	.github/workflows/ci.yml
2	0	include/keepkey/board/layout.h
1	1	include/keepkey/firmware/app_layout.h
4	0	include/keepkey/firmware/recovery_cipher.h
5	0	lib/board/layout.c
9	5	lib/firmware/app_layout.c
8	2	lib/firmware/fsm.c
2	0	lib/firmware/fsm_msg_binance.h
23	7	lib/firmware/fsm_msg_common.h
2	0	lib/firmware/fsm_msg_cosmos.h
2	0	lib/firmware/fsm_msg_mayachain.h
30	3	lib/firmware/fsm_msg_osmosis.h
2	0	lib/firmware/fsm_msg_tendermint.h
2	0	lib/firmware/fsm_msg_thorchain.h
35	3	lib/firmware/recovery_cipher.c
6	0	lib/firmware/reset.c
7	0	scripts/emulator/python-keepkey-tests.sh
121	0	scripts/generate-test-report.py
99	1	scripts/test_generate_test_report.py
139	0	scripts/tests/test_block13_entropy.py
3	0	unittests/firmware/CMakeLists.txt
461	0	unittests/firmware/block13_confirmation.cpp
424	0	unittests/firmware/block13_entropy.cpp
621	0	unittests/firmware/block13_progress.cpp
21	0	unittests/firmware/fsm.cpp
4	0	unittests/firmware/recovery.cpp
5	0	unittests/firmware/rng_health.cpp
12	5	docs/release/RELEASE-PROGRAM.md
19	0	docs/release/audit-units/715-13-evidence/block13-btc.xml

Added	Deleted	Path
6	0	docs/release/audit-units/715-13-evidence/block13-focused.xml
34	0	docs/release/audit-units/715-13-evidence/block13-negative.log
23	0	docs/release/audit-units/715-13-evidence/block13-negative.xml
22	0	docs/release/audit-units/715-13-evidence/block13-recovery.xml
22	0	docs/release/audit-units/715-13-evidence/block13-restored.xml
110	0	docs/release/audit-units/715-13-final-audit-20260929.md
-	-	docs/release/audit-units/715-13-final-audit-20260929.pdf
-	-	docs/release/audit-units/715-13-final-controls-20260929.tgz
78	0	docs/release/audit-units/715-13-first-checks-20260927.json
71	0	docs/release/audit-units/715-13-historical-commits-20260927.json
121	0	docs/release/audit-units/715-13-intake-20260927.md
668	0	docs/release/audit-units/715-13-path-reconciliation-20260927.json
152	0	docs/release/audit-units/715-13-progress-review.md
59	12	docs/release/audit-units/source-storage-policy.md